

NIST CSF 2.0

Step 7 — Gap Assessment Report

Executive Assessment | Current vs Target Profile | Function-Level Findings | Remediation Roadmap

Organization	LearnSphere EdTech
Assessment Scope	Cloud-hosted LMS, AWS environment, student/teacher data, IAM, application, databases, endpoints, monitoring, backups and relevant third parties.
Assessment Focus	Minors' data: parental-consent and data-minimization governance; access controls for student records.
Framework	NIST Cybersecurity Framework (CSF) 2.0
Assessment Date	07-Sep-2026
Document ID	LS-NIST-003 Version 1.0

Executive conclusion: LearnSphere has a partially repeatable security foundation, but governance of children's data, authoritative data inventory, student-record access, monitoring correlation and recovery improvement require formalization. The assessment produces an overall current score of **1.79/4** against a target of **3.04/4**, an overall gap of **1.25**.

Prepared By — Mr. Meejan Shaikh, GRC Analyst | **Reviewed By** — Information Security Manager | **Approved By** — CISO

1. Executive Summary

LearnSphere EdTech operates a cloud-hosted learning platform and processes sensitive information relating to students, teachers, school administrators and employees. Because the environment includes minors' data, the assessment places additional emphasis on privacy governance, parental consent, data minimization and strong access control for student records.

The assessment indicates that security practices are present but unevenly formalized. The strongest relative area is Respond at 2.00/4, while Govern, Identify, Protect and Detect each average 1.75/4. Protect is the highest-priority function because student-record access governance has a critical gap and requires a target of 4 for PR.AA-05.

The remediation objective is not to implement every possible security practice at once. Instead, the roadmap prioritizes outcomes that reduce risk to minors' data, improve accountability and establish repeatable evidence that can be measured and reviewed.

2. Scope and Objectives

Scope Area	Included
Technology	AWS infrastructure, LMS application, databases, IAM, source-code repositories, CI/CD, backups, SIEM/security monitoring and employee endpoints.
Information	Student personal data, assessment/academic records, teacher/staff data and related identity/access information.
Third Parties	Cloud service provider, payment gateway and relevant security/service providers.
Objectives	Assess selected CSF 2.0 outcomes, compare current and target states, identify material gaps, prioritize remediation and establish a management-level roadmap.

The assessment is designed as an organizational-profile exercise: the Current Profile represents the present state of selected cybersecurity outcomes, while the Target Profile represents a realistic desired state used to identify and prioritize gaps.

3. Methodology

Step 1 — Define context. The assessment used LearnSphere's operating model, cloud architecture, sensitive-data profile and stated focus on minors' data as the business context.

Step 2 — Select outcomes. Four relevant CSF 2.0 outcomes were selected under each of the six Functions, giving 24 assessed outcomes. Selection emphasized governance, data inventory, risk assessment, access control, detection, response and recovery.

Step 3 — Establish current state. Each selected outcome was scored using the project's internal 0–4 maturity scale based on the documented/ad hoc posture: 0 Not Performed, 1 Ad Hoc, 2 Repeatable, 3 Defined, 4 Managed/Optimized.

Step 4 — Set target state. Most outcomes were assigned a target of 3 because the practical objective is a defined, consistently implemented and evidenced capability. PR.AA-05 was assigned target 4 due to the sensitivity of student records and the need for managed access governance.

Step 5 — Determine gaps. Gap = Target – Current. Larger gaps indicate greater maturity distance; priority also considers the potential impact on minors' data, access exposure, regulatory/contractual expectations and dependency on foundational capabilities.

NIST alignment note: NIST CSF 2.0 itself does not prescribe this 0–4 maturity scale. The scale is an internal project scoring method used to make the Current/Target Profile comparison measurable.

Scoring reference

Score	Internal meaning
0	Outcome not performed; no credible evidence.
1	Inconsistent, informal or reactive practice.
2	Some consistency exists, but documentation, coverage or measurement is incomplete.
3	Formally documented, assigned, consistently implemented and integrated.
4	Managed, measured, reviewed for effectiveness and continuously improved.

4. Overall Function Summary

Function	Current	Target	Gap	Priority	Management interpretation
Govern	1.75	3.00	1.25	High	Children's-data requirements and ownership need formal operational translation.
Identify	1.75	3.00	1.25	High	Authoritative data inventory and data-risk linkage require strengthening.
Protect	1.75	3.25	1.50	Critical	Student-record access and lifecycle protection are the most urgent control gaps.
Detect	1.75	3.00	1.25	High	Monitoring coverage, investigation metrics and event correlation need definition.

Function	Current	Target	Gap	Priority	Management interpretation
Respond	2.00	3.00	1.00	Medium-High	Incident handling is present but needs child-data-specific consistency.
Recover	1.75	3.00	1.25	Medium	Recovery dependencies and lessons-learned improvement need formalization.

Overall current state: 1.79/4 Overall target: 3.04/4 Overall gap: 1.25

5. GOVERN FUNCTION — Detailed Findings

Function average: Current 1.75 | Target 3.00 | Gap 1.25 | Priority High

Subcategory	Current	Target	Gap	Priority	Current-state finding
GV.OC-03	1	3	2	High	Legal, regulatory, contractual and privacy requirements, including children's-data and parental-consent expectations, are not consistently translated into operational requirements.
GV.RM-01	2	3	1	High	Cyber risk assessment is not consistently integrated into new student-data processing, product changes and related decisions.
GV.RR-02	2	3	1	High	Ownership and accountability for children's-data governance, consent and minimization are not consistently formalized.
GV.PO-01	2	3	1	High	Policies do not consistently translate children's-data protection into collection, consent, minimization, access and retention requirements.

Management implication: establish clear ownership for children's-data obligations, consent, minimization and policy translation.

6. IDENTIFY FUNCTION — Detailed Findings

Function average: Current 1.75 | Target 3.00 | Gap 1.25 | Priority High

Subcategory	Current	Target	Gap	Priority	Current-state finding
ID.AM-02	2	3	1	High	Software and services inventory is not consistently linked to the student-data types and business processes they support.
ID.AM-07	1	3	2	High	Authoritative inventory and metadata for designated or sensitive student data are incomplete.
ID.RA-04	2	3	1	High	Changes to student-data processing do not consistently trigger a structured risk or privacy assessment.
ID.RA-05	2	3	1	High	Data-minimization risk is not consistently treated as an explicit part of risk assessment.

Management implication: create an authoritative inventory linking systems, data types, purposes, owners and risk.

7. PROTECT FUNCTION — Detailed Findings

Function average: Current 1.75 | Target 3.25 | Gap 1.50 | Priority Critical

Subcategory	Current	Target	Gap	Priority	Current-state finding
PR.AA-05	2	4	2	Critical	Access permissions, entitlements and privileged access for student records are not consistently governed through evidence-based least privilege, separation of duties and recurring review.
PR.AA-03	2	3	1	High	Authentication requirements vary across systems and access paths, creating inconsistent assurance for sensitive student records.
PR.DS-01	2	3	1	High	Protection of student data is not consistently mapped across the full information lifecycle.
PR.DS-10	1	3	2	High	Retention and disposal requirements are not consistently enforced through defined schedules, deletion mechanisms and verification.

Management implication: prioritize least privilege, separation of duties, privileged access governance and lifecycle protection.

8. DETECT FUNCTION — Detailed Findings

Function average: Current 1.75 | Target 3.00 | Gap 1.25 | Priority High

Subcategory	Current	Target	Gap	Priority	Current-state finding
DE.CM-01	2	3	1	High	Monitoring coverage for critical assets and student-data environments is not consistently measured.
DE.CM-06	2	3	1	High	Third-party monitoring expectations and evidence requirements are inconsistent.
DE.AE-02	2	3	1	High	Alert investigation does not consistently use metrics such as MTTD and MTTL.
DE.AE-04	1	3	2	High	Correlation between IAM activity, application events and student-record access is not consistently defined.

Management implication: define monitoring coverage, investigation metrics and correlation use cases for sensitive data access.

9. RESPOND FUNCTION — Detailed Findings

Function average: Current 2.00 | Target 3.00 | Gap 1.00 | Priority Medium-High

Subcategory	Current	Target	Gap	Priority	Current-state finding
RS.MA-01	2	3	1	Medium-High	Incident severity and handling do not consistently distinguish events involving children's data or student records.
RS.AN-03	2	3	1	Medium-High	Evidence collection and analysis for unauthorized student-record access are not standardized.
RS.CO-02	2	3	1	Medium-High	Communication and escalation roles for student-data incidents are not consistently defined.
RS.MI-01	2	3	1	Medium-High	Predefined playbooks for compromised student records are incomplete.

Management implication: formalize classification, evidence handling, communications and student-record incident playbooks.

10. RECOVER FUNCTION — Detailed Findings

Function average: Current 1.75 | Target 3.00 | Gap 1.25 | Priority Medium

Subcategory	Current	Target	Gap	Priority	Current-state finding
RC.RP-01	2	3	1	Medium	Recovery testing is not consistently scenario-based for ransomware, database compromise and student-data loss.
RC.RP-03	2	3	1	Medium	Recovery priorities and dependencies are not consistently documented against RTO/RPO expectations.
RC.CO-02	2	3	1	Medium	Communication requirements for student-service disruptions need clearer definition.
RC.IM-01	1	3	2	Medium	Lessons learned are not systematically converted into tracked, owned and verified improvements.

Management implication: make recovery testing scenario-based and ensure lessons learned become tracked improvement actions.

11. Cross-Functional Gap Themes

Gap	Theme	NIST linkage	Assessment finding	Priority
GAP-01	Children's-data governance	GV.OC-03 / GV.RR-02 / GV.PO-01	Operational requirements for children's data are not consistently defined and owned.	High
GAP-02	Parental-consent governance	GV.OC-03 / GV.PO-01 / ID.RA-04	Consent requirements are not consistently translated into product and processing controls.	High
GAP-03	Student-data inventory	ID.AM-02 / ID.AM-07	Authoritative data inventory and metadata are incomplete.	High
GAP-04	Data minimization	ID.RA-05 / PR.DS-10	Collection, retention and disposal are not consistently governed against purpose.	High
GAP-05	Student-record access	PR.AA-05 / PR.AA-03	Least privilege, SoD and recurring access certification need stronger governance.	Critical
GAP-06	Detection correlation	DE.CM-01 / DE.AE-04	IAM, application and student-record activity are not consistently correlated.	High
GAP-07	Children's-data incident response	RS.MA-01 / RS.AN-03 / RS.CO-02 / RS.MI-01	Incident handling needs stronger child-data-specific classification, evidence and playbooks.	Medium-High
GAP-08	Recovery and improvement	RC.RP-01 / RC.RP-03 / RC.IM-01	Recovery testing and lessons-learned tracking need formalization.	Medium

Highest-risk theme: Student-record access (GAP-05) is the critical priority because unauthorized access to minors' records can create confidentiality, privacy and contractual exposure. This gap is directly addressed through PR.AA-05 and PR.AA-03 remediation.

12. Remediation Roadmap

The roadmap is sequenced so that governance and foundational data/access decisions are completed before broader optimization. Each phase should produce evidence that can be sampled during internal assurance activities.

Phase	Priority activities
0–3 Months	Establish children's-data governance ownership; document parental-consent requirements; create designated student-data inventory baseline; perform emergency student-record and privileged-access review; address excessive collection; require data-processing risk assessment for material changes.
3–6 Months	Build authoritative data inventory and data-flow mapping; implement data-minimization and retention rules; establish quarterly access certification; standardize authentication requirements; implement children's-data incident playbook; define monitoring KPIs and detection correlation use cases.

Phase	Priority activities
6–12 Months	Run scenario-based recovery exercises; mature security metrics; integrate product/change risk into governance; strengthen third-party monitoring evidence; formalize lessons-learned improvement tracking; reassess the NIST Target Profile and update the remediation roadmap.

Recommended ownership

Workstream	Primary owner	Key evidence
Children's-data governance	Privacy / Information Security	Requirements register, consent requirements, ownership/RACI, policy updates
Data inventory & minimization	Data Owners + GRC	Data inventory, data flows, purpose/retention fields, risk assessments
Student-record access	IAM / Information Security	RBAC matrix, privileged register, quarterly certification, exceptions
Monitoring & response	SOC / Information Security	Coverage metrics, correlation rules, incident playbooks, investigation records
Recovery & improvement	IT Operations + GRC	Exercise results, RTO/RPO evidence, lessons-learned tracker, closure verification

13. Closing Recommendation

LearnSphere should approve the Target Profile as the management direction and execute the roadmap in the stated sequence. Immediate attention should be given to children's-data governance, parental consent, authoritative student-data inventory, data minimization and student-record access governance. These foundational activities reduce the likelihood of inappropriate collection, retention or access and create the evidence base required for later monitoring and assurance.

Management should review progress at least quarterly using measurable indicators such as access-review completion, privileged-account certification, inventory coverage, retention/disposal compliance, monitoring coverage, incident-response exercise completion and closure of improvement actions. After the 6–12 month phase, the Current Profile should be reassessed against the Target Profile and the roadmap refreshed.

14. Approval and Governance

Role	Name / responsibility	Signature	Date
Prepared By	Mr. Meejan Shaikh – GRC Analyst	_____	07-Sep-2026
Reviewed By	Information Security Manager	_____	07-Sep-2026
Approved By	CISO	_____	07-Sep-2026

15. References and Document Basis

1. NIST Cybersecurity Framework (CSF) 2.0 — NIST Cybersecurity White Paper 29, 2024. 2. NIST CSF 2.0 Organizational Profiles guidance. 3. NIST SP 1302 — NIST Cybersecurity Framework 2.0: Small Business Quick-Start Guide. 4. LearnSphere project baseline and outputs from Steps 3–6: assessment, target maturity, gap assessment and prioritized remediation roadmap.

Document control: This report is an internal assessment deliverable. It should be reviewed when the LearnSphere operating model, regulatory requirements, technology environment, material processing activities or risk profile changes.